

Requisitos generales para la integración del Proyecto Integrador

Detección automática y registros de incidentes

El sistema debe contar con mecanismos que permitan identificar eventos sospechosos o anómalos sin intervención manual.

- ✓ Registro automático de eventos (logs)
- ✓ Monitoreo de:
 - Intentos fallidos de inicio de sesión
 - Accesos fuera de horario
 - Cambios no autorizados en registros
 - Intentos de XSS (Cross-Site Scripting)
 - Intentos de acceso indebido tipo IDOR (Insecure Direct Object Reference)
 - Intentos de inyección SQL o entradas sospechosas
- ✓ Generación automática de alertas cuando se detecte un comportamiento anómalo
- ✓ Almacenamiento de incidentes en base de datos con fecha, hora, usuario y descripción del evento
- ✓ Bitácora

Clasificación y priorización de incidentes

El sistema debe evaluar los incidentes detectados y asignarles un nivel de gravedad para determinar el orden de atención.

- ✓ Definición de niveles de severidad (Bajo, Medio, Alto, Crítico)
- ✓ Criterios de clasificación basados en impacto y alcance
- ✓ Asignación automática o manual de prioridad
- ✓ Visualización de incidentes ordenados por nivel de riesgo
- ✓ Estado del incidente (Abierto, En proceso, Resuelto, Cerrado)

Mecanismo de contención

El sistema debe incluir acciones inmediatas para evitar que el incidente se propague o cause mayor daño.

- ✓ Bloqueo automático de cuentas tras múltiples intentos fallidos
- ✓ Implementación de CAPTCHA y reCAPTCHA
- ✓ Cierre o invalidación de sesiones sospechosas (Acceso Prohibido)
- ✓ APIs (OAuth 2.0, tokens JWT)
- ✓ Restricción temporal de acceso a módulos afectados
- ✓ Registro de acciones de contención en la bitácora
- ✓ Notificación al responsable de seguridad

Procedimientos de erradicación de amenazas

El sistema debe permitir eliminar la causa raíz del incidente detectado.

- ✓ Uso obligatorio de consultas preparadas (prepared statements)
- ✓ Implementación de tokens CSRF
- ✓ Validación de entradas en backend
- ✓ Restablecimiento de credenciales comprometidas (cambio de contraseña y cierre de sesiones activas)
- ✓ Corrección de registros alterados mediante historial o respaldo
- ✓ Documentación del procedimiento aplicado
 - Identificación de vulnerabilidad explotada (XSS, IDOR, SQLi)
 - Corrección de código vulnerable
 - Registro de corrección
 - Registro del cierre técnico del incidente
- ✓ Validación de que la amenaza fue eliminada

Recuperación controlada de servicios y datos afectados

El sistema debe restaurar el funcionamiento normal garantizando que no exista riesgo residual.

- ✓ Mecanismo de respaldo de información
- ✓ Restauración de datos afectados*
- ✓ Verificación de integridad después de la recuperación
- ✓ Pruebas funcionales del sistema restaurado
- ✓ Confirmación de restablecimiento del servicio
- ✓ Registro en Bitácora de Recuperación

Garantía de confidencialidad, integridad y disponibilidad

El sistema debe demostrar que protege los tres pilares fundamentales de la seguridad de la información.

- ✓ Confidencialidad:
 - Control de acceso basado en roles
 - Cifrado o hash seguro de contraseñas
 - Protección contra inyección SQL
 - Gestión segura de sesiones
 - Verificación de doble factor (2FA)
 - Protección contra IDOR
- ✓ Integridad:

- Validación de datos de entrada
- Restricciones de integridad en base de datos (PRIMARY KEY, FOREIGN KEY, NOT NULL)
- Registro de auditoría de cambios
- Protección de la bitácora contra alteraciones
- Uso de VISTAS (VIEW) para limitar exposición de datos sensibles
- Prevención de XSS
- ✓ Disponibilidad:
 - Mecanismos de respaldo
 - Replicación de base de datos
 - Control de intentos de acceso para evitar abuso
 - Manejo adecuado de errores del sistema
 - Plan básico de continuidad operativa simulado (cambio de DB)

Creación de políticas de seguridad

Política de Uso del Sistema

- ✓ Reglas de acceso
- ✓ Prohibiciones
- ✓ Sanciones

Política del Proceso de Respuesta a Incidentes

- ✓ Detección
- ✓ Análisis
- ✓ Contención
- ✓ Erradicación
- ✓ Recuperación
- ✓ Lecciones aprendidas

Política de Protección de Datos

- ✓ Clasificación de información
- ✓ Tratamiento de datos sensibles
- ✓ Confidencialidad

Política de Gestión de Contraseñas

- ✓ Longitud mínima
- ✓ Complejidad obligatoria
- ✓ Caducidad
- ✓ Bloqueo por intentos fallidos

Política del Personal

- ✓ Responsabilidades del administrador
- ✓ Responsabilidades del analista de seguridad
- ✓ Responsabilidades del usuario final